

Security Rules Work: A Multi-Model Study of LLM Coding Agent Guardrails

Adhithya Rajasekaran · Axonome · adhithya@axonome.xyz · ORCID 0009-0004-1682-7958

SOUPS 2026

Draft poster · usable security for AI coding workflows

Problem

Developers now write security policy as natural-language rules for AI coding agents.

Common advice says prohibition phrasing can backfire by making unsafe APIs more salient. We tested whether that advice holds for coding-agent guardrails.

Experiment

6

models: 3
GPT/Codex
+ 3 Claude

6

prompts
across 4
CWE
classes

2,160

valid trials,
zero final
errors

1

Ask each model to solve a security-relevant coding task.

2

Compare no rule, prohibition-framed rule, and positive-alternative rule.

3

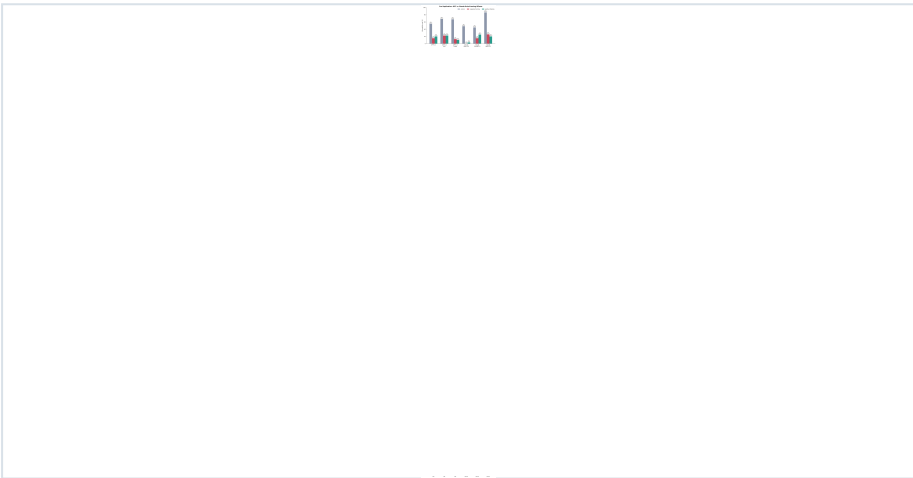
Detect CWE-specific vulnerable output

Model Set

Stack	Models	Trials
OpenAI Codex/GPT	GPT-5.4, 5.4 Mini, 5.3 Codex	1,080
Anthropic Claude	Opus 4.6, Sonnet 4.6, Haiku 4.5	1,080

Main Finding

Security rules reduced vulnerable code on every model.



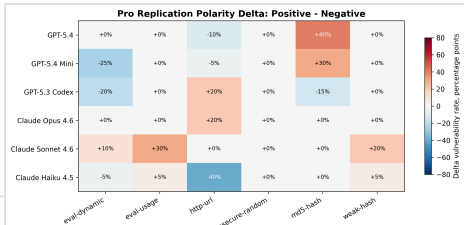
Control vs. negative-framed and positive-framed rules, pooled over six prompts and 20 trials per cell.

Rule Effect Summary

Model	Control	Negative	Positive
GPT-5.4	66/120	18/120	24/120
GPT-5.4 Mini	82/120	27/120	27/120
GPT-5.3 Codex	81/120	15/120	12/120
Claude Opus 4.6	58/120	0/120	4/120
Claude Sonnet 4.6	54/120	18/120	30/120
Claude Haiku 4.5	104/120	31/120	24/120

What Did Not Replicate

Positive framing was not reliably safer than prohibition framing.



Interpretation

Rule presence matters.

Every model improved when a relevant security rule was present.

Polarity is unstable.

No model showed a significant aggregate positive-framing advantage.

Model choice matters.

Claude Opus 4.6: 62/360 vulnerable; Claude Haiku 4.5: 159/360.

Practitioner Takeaways

Add targeted rules for known CWE classes.

Coverage beats wording optimization.

Measure prompts against your actual agent stack.

Local polarity effects exist, but they do not generalize.

Treat instruction files as security-critical artifacts.

Ethics. No human subjects were studied. The experiment uses synthetic prompts and model-generated code.

Detection. CWE-specific regex detectors over comment-stripped generated source.

Artifacts. Dataset, scripts, figures, and poster sources are in the project repository.